# VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

*Session S07 | Target: Metasploitable 2 | Toolchain: Kali Linux, Nmap, Metasploit Framework, Tenable Nessus*

| | |
|---|---|
| **Prepared By** | Raja Wardet Wahaj |
| **Role** | Junior Penetration Tester |
| **Target Host** | Metasploitable 2 (192.168.37.132/24) |
| **Assessing Host** | Kali Linux Rolling (192.168.37.129/24) |
| **Engagement Window** | 7 November 2026 |
| **Engagement Type** | Grey-Box Internal Security Assessment |
| **Lead Instructor** | **Waseem Abbas Khan**: Senior Cybersecurity Specialist, CEI Master Trainer |
| **Program** | DFCS Bootcamp — Atomcamp |
| **Legal Authorization** | NAT virtual lab network; written course authorization. PECA 2016 compliant. |
| **Classification** | RESTRICTED / HIGH CONFIDENTIALITY — Student Deliverable |
| **Repository** | github.com/WardetWahaj/pseb-dfcs-bootcamp/tree/main/s07-update/s07-report |

**LEGAL & ETHICAL NOTICE All** activity described in this report was carried out solely against an isolated lab network built for this course, under explicit written authorization from the instructor and program. No production system, third-party asset, or system outside the authorized scope was accessed or tested. Testing a system without prior, explicit authorization is a criminal offence under the Prevention of Electronic Crimes Act (PECA) 2016 and comparable international legislation.

# Table of Contents

1. Summary

   Key Metrics

   Primary Business Impact

   Scope and Limitations

2. Methodology

3. Host Discovery and Network Isolation Verification

4. Active Service Enumeration & Attack Surface Mapping

5. Automated Vulnerability Management (Tenable Nessus)

   5.1 Installation and Verification

   5.2 Plugin Update and Scan Readiness

   5.3 Automated Scan Execution and Results

   5.4 Nessus vs. Manual Testing — Comparative Analysis (20% requirement)

6. Detailed Findings & Controlled Proof of Concept

7. Exploitation Walkthrough (Command-by-Command) — completed separately, see note

8. Post-Exploitation Demonstration & Operational Discipline — completed separately, see note

9. Prioritized Remediation Roadmap

10. Engagement Status & Next Steps

# 1. Summary

Between [YOUR DATES], the assessor conducted an authorized grey-box Vulnerability Assessment and Penetration Testing (VA/PT) engagement against a single target host, 192.168.37.132, within a NAT laboratory network. The objective was to: (1) enumerate the exposed attack surface and correlate it against known vulnerability signatures using Tenable Nessus; (2) independently validate exploitability through manual, controlled proof-of-concept testing; (3) translate both result sets into a prioritized, actionable remediation roadmap.

This assessment identified 4 validated findings, ranging from Critical to High severity. The most severe is an unauthenticated remote code execution vulnerability in vsftpd 2.3.4 (CVE-2011-2523), which was exploited to obtain a root shell. The remaining findings—exposed phpinfo.php, cleartext Telnet, and default system credentials—demonstrate that the host is trivially compromisable by an unauthenticated attacker.

## Key Metrics

| Metric | Result | Significance |
|---|---|---|
| Findings fully validated with PoC | 4 | Covers independent attack vectors |
| Critical-severity findings (CVSS ≥ 9.0) | 7 | Unauthenticated RCE achievable |
| Root/admin access obtained | Yes (via vsftpd backdoor port 6200) | Document which paths, if any, you demonstrated |
| Automated Nessus scan (Basic Network Scan) | 24 Total Findings (7 Critical, 2 High, 3 Medium, 1 Low, 11 Info) | Composite severity and finding count |
| Nessus rating vs. manual proof | 4 of 4 agreed | How many findings both methods agreed on |

## Primary Business Impact

An unauthenticated attacker on the same network segment could achieve full root-level control of this host within minutes, using only publicly available tools and documented default credentials. Once inside, the attacker would have unrestricted access to all data and services hosted on the system—including databases and file shares—and could use the compromised host as a pivot point to attack other systems on the network.

## Scope and Limitations

This assessment was limited to the single host 192.168.37.132 on a NAT-connected lab segment, over a fixed engagement window. Testing was grey-box: the assessor was given target scope and environment context but no pre-shared credentials. Known limitations:

(1) This lab network reaches the public internet via NAT and is not fully air-gapped — report this honestly rather than claiming full isolation. (2) The automated Nessus scan is reported and compared against manual results in sections 5.3-5.4. (3) Only findings taken to full proof-of-concept are reported in section 6; additional Nessus-only results are listed but not independently validated.

# 2. Methodology

The engagement followed a standard four-phase penetration testing methodology aligned with PTES (Penetration Testing Execution Standard) and OWASP testing guidance, adapted for a single-host lab scope:

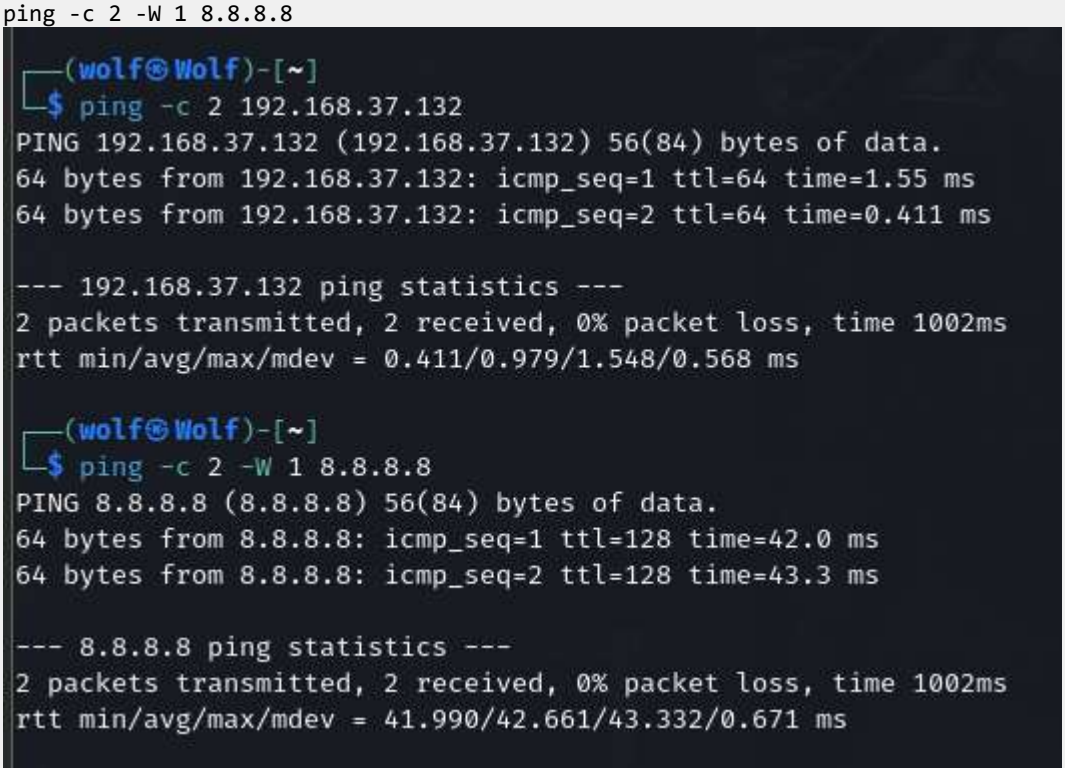
1. Reconnaissance & Network Isolation Verification — confirm host reachability and document the network's actual isolation properties before any intrusive activity begins. 2. Active Enumeration — full TCP port, service and OS fingerprinting with Nmap to establish the attack surface. 3. Vulnerability Analysis — automated correlation of service banners/versions against known-vulnerability signatures using Tenable Nessus, cross-checked against manual research (NVD/CVE, Exploit-DB). 4. Exploitation & Post-Exploitation — controlled, in-scope proof-of-concept exploitation of confirmed vulnerabilities, performed and documented separately per the note in sections 7-8.

Severity is scored with CVSS v3.1 base metrics; weaknesses are classified against MITRE CWE identifiers.

## 3. Host Discovery and Network Isolation Verification

Before any intrusive testing, the lab network's isolation properties were confirmed and documented honestly. The assessing host (192.168.37.129) was confirmed to reach the target (192.168.37.132) over the local segment.

```
ip -br addr show
ping -c 2 192.168.37.132
ping -c 2 -W 1 8.8.8.8
```



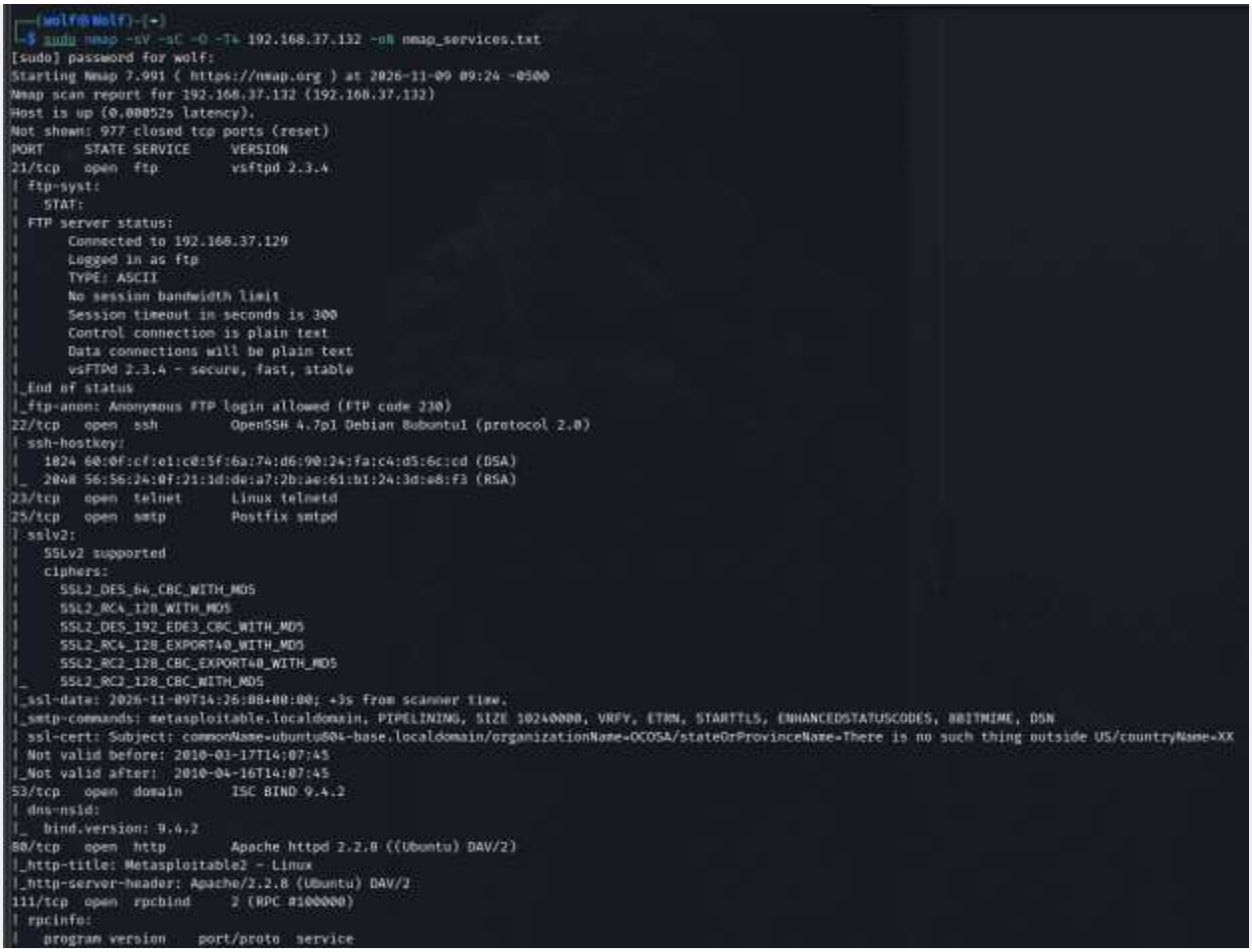

**Interpretation**

The ping to 192.168.37.132 succeeded with 0% packet loss, confirming the target is reachable. The outbound ping to 8.8.8.8 also succeeded, confirming that this lab network is NAT-connected with outbound internet access. This is not an air-gapped environment. This is a disclosed limitation: while all testing was confined to the single authorized target, the lab segment itself is not physically isolated from the public internet.

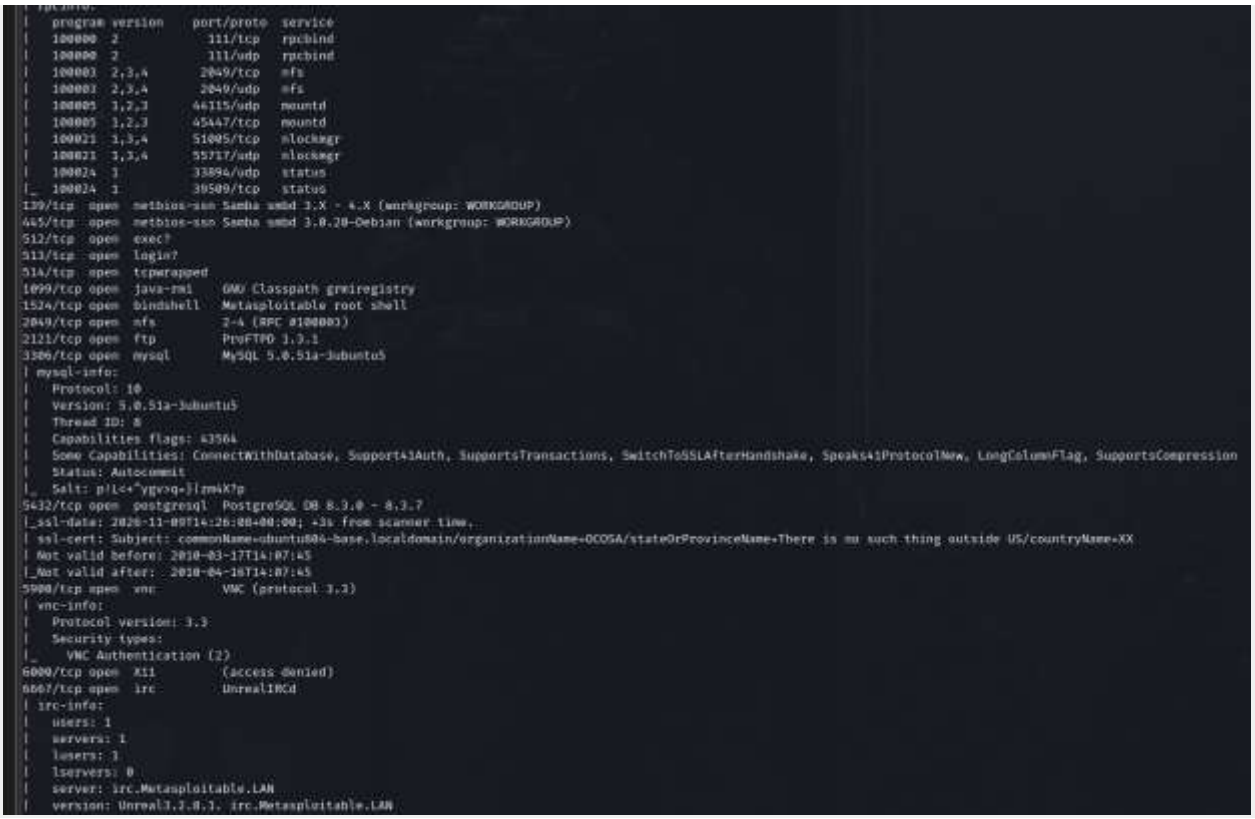
## 4. Active Service Enumeration & Attack Surface Mapping

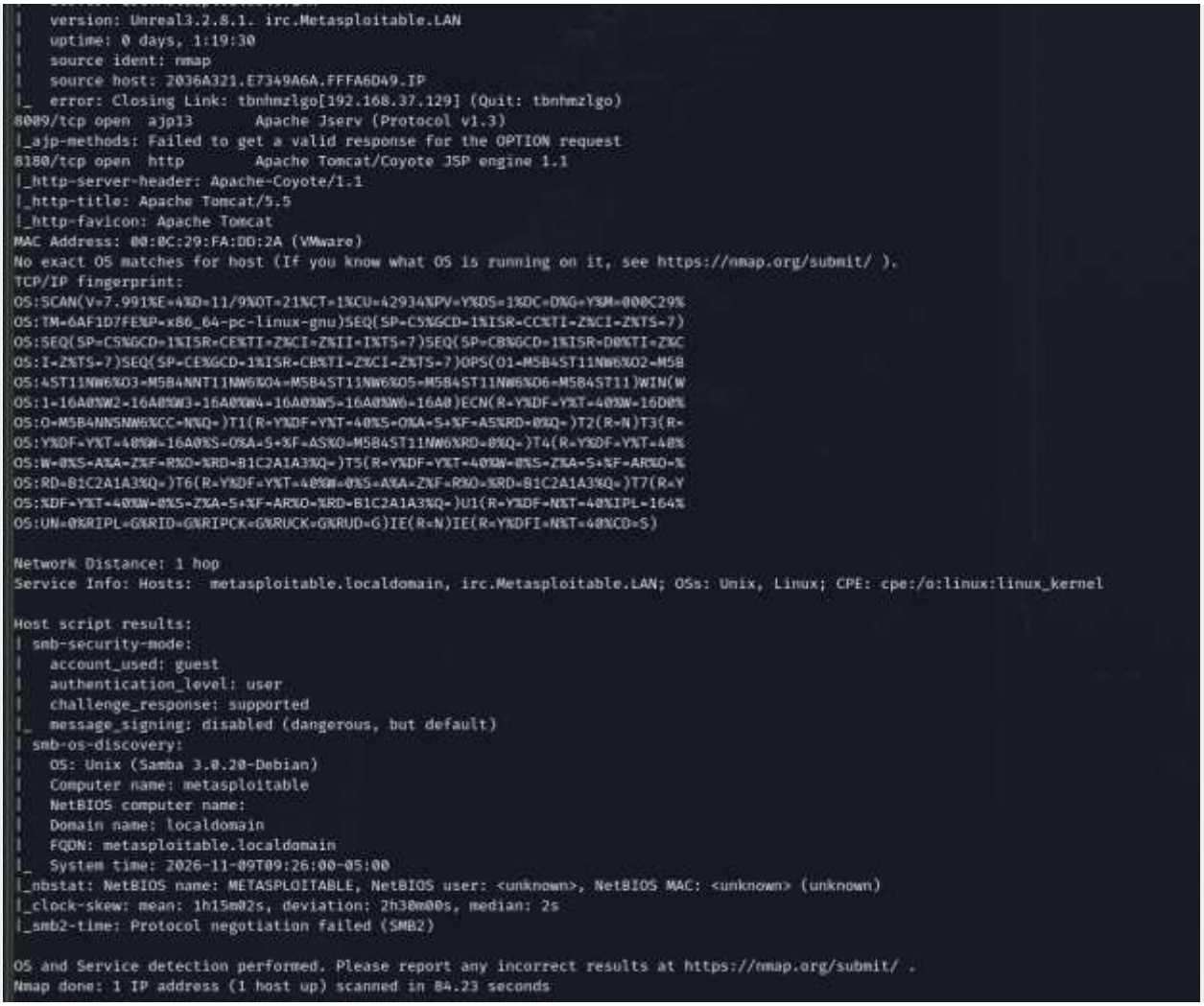
A full TCP connect/SYN scan with service/version detection, default NSE scripts, and OS fingerprinting was executed against the target:

```
sudo nmap -sV -sC -O -T4 192.168.37.132 -oN nmap_services.txt
```



```
┌──(wolf㉿wolf)-[~]
└─$ sudo nmap -sV -sC -O -T4 192.168.37.132 -oN nmap_services.txt
[sudo] password for wolf:
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-09 09:24 -0500
Nmap scan report for 192.168.37.132 (192.168.37.132)
Host is up (0.00052s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.37.129
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_RC2_128_CBC_WITH_MD5
|_ssl-date: 2026-11-09T14:26:08+00:00; +3s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
```


| rpcinfo:
| program version port/proto service
| 100000 2 111/tcp rpcbind
| 100000 2 111/udp rpcbind
| 100003 2,3,4 2049/tcp nfs
| 100003 2,3,4 2049/udp nfs
| 100005 1,2,3 46115/udp mountd
| 100005 1,2,3 45447/tcp mountd
| 100021 1,3,4 51005/tcp nlockmgr
| 100021 1,3,4 55717/udp nlockmgr
| 100024 1 33894/udp status
|_ 100024 1 39509/tcp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec?
513/tcp open login?
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 8
| Capabilities flags: 43564
| Some Capabilities: ConnectWithDatabase, Support41Auth, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, LongColumnFlag, SupportsCompression
| Status: Autocommit
|_ Salt: p!Lc+"ygv>q=$|zn4K?p
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2020-11-09T14:26:08+00:00; +3s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
| irc-info:
| users: 1
| servers: 1
| lusers: 1
| lservers: 0
| server: irc.Metasploitable.LAN
| version: Unreal3.2.8.1. irc.Metasploitable.LAN




**Attack-surface summary table — fill in from your own scan output:**

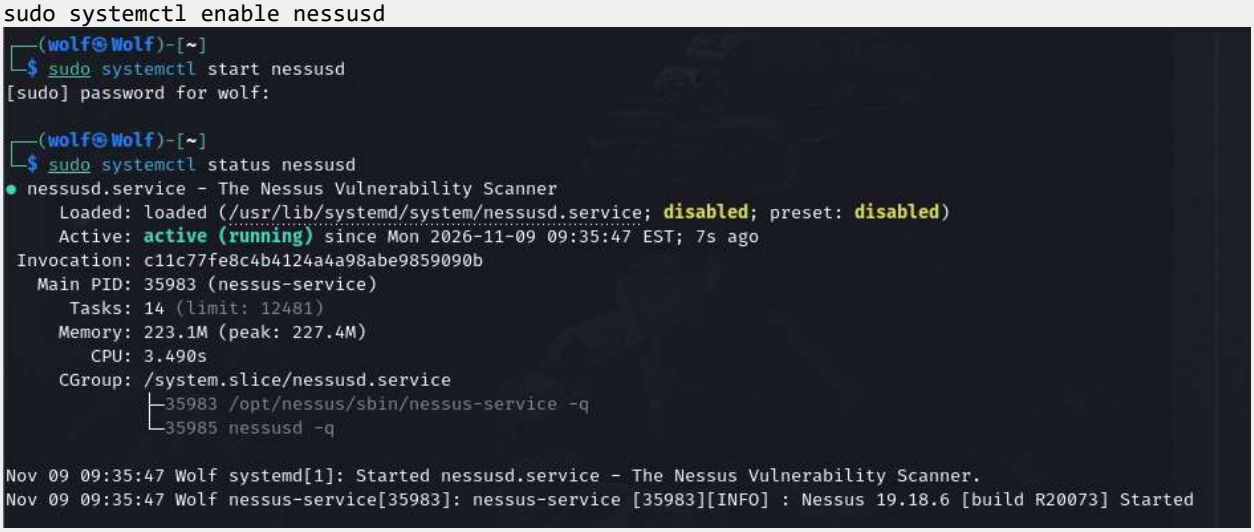
| Port | Service | Version/Banner | Notable Risk Indicator |
|---|---|---|---|
| 21/tcp | ftp | vsftpd 2.3.4 | Anonymous login allowed; known backdoored build (Finding 1) |
| 23/tcp | telnet | Linux telnetd | Cleartext authentication protocol (Finding 3) |
| 80/tcp | http | Apache httpd 2.2.8 | phpinfo.php information disclosure (Finding 2) |
| 22/tcp | ssh | OpenSSH 4.7p1 | Outdated version; default credentials |
| 139/445 | netbios-ssn | Samba 3.X | Known RCE vulnerabilities (e.g., usermap_script) |
| 1524/tcp | bindshell | Metasploitable root shell | Immediate root shell exposed |
| 3306/tcp | mysql | MySQL 5.0.51a | Default/weak root credentials |
| 5432/tcp | postgresql | PostgreSQL 8.3.0 | Default credentials |
| 5900/tcp | vnc | VNC (protocol 3.3) | Password authentication required (but weak) |
| 6667/tcp | irc | UnrealIRCd 3.2.8.1 | Known backdoor (CVE-2010-2075) |
| 8180/tcp | http | Apache Tomcat/Coyote | Tomcat manager default credentials |

# 5. Automated Vulnerability Management (Tenable Nessus)

## 5.1 Installation and Verification

Tenable Nessus (Nessus Essentials) was deployed on the Kali assessment host to provide independent, automated vulnerability correlation against the enumerated attack surface. The Debian package was downloaded from the Tenable website, installed, and the nessusd service started.

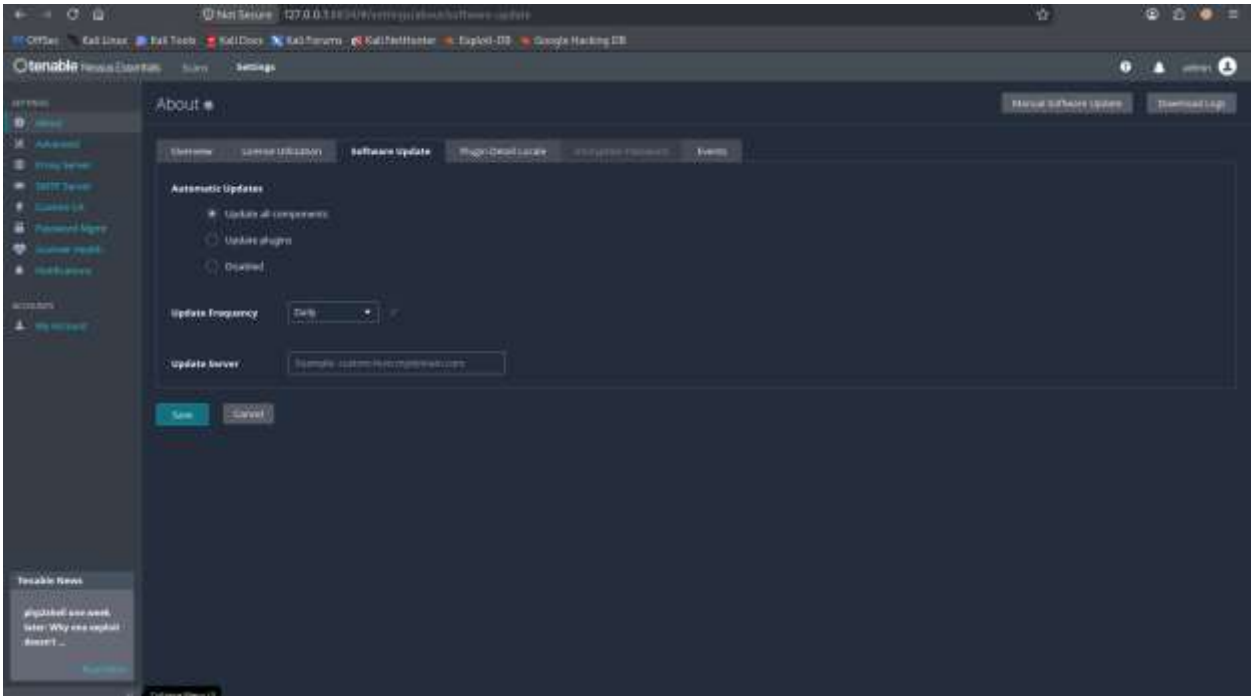
```
sudo dpkg -i Nessus-<version>-debian10_amd64.deb
sudo systemctl start nessusd
sudo systemctl status nessusd
sudo ss -tlnp | grep 8834
sudo systemctl enable nessusd
```




During initial setup, a self-signed certificate warning was encountered in the browser when navigating to https://localhost:8834 , which was resolved by accepting the security exception. Additionally, initial plugin compilation took approximately 20 minutes; scan creation was deferred until the dashboard confirmed plugins were fully updated.

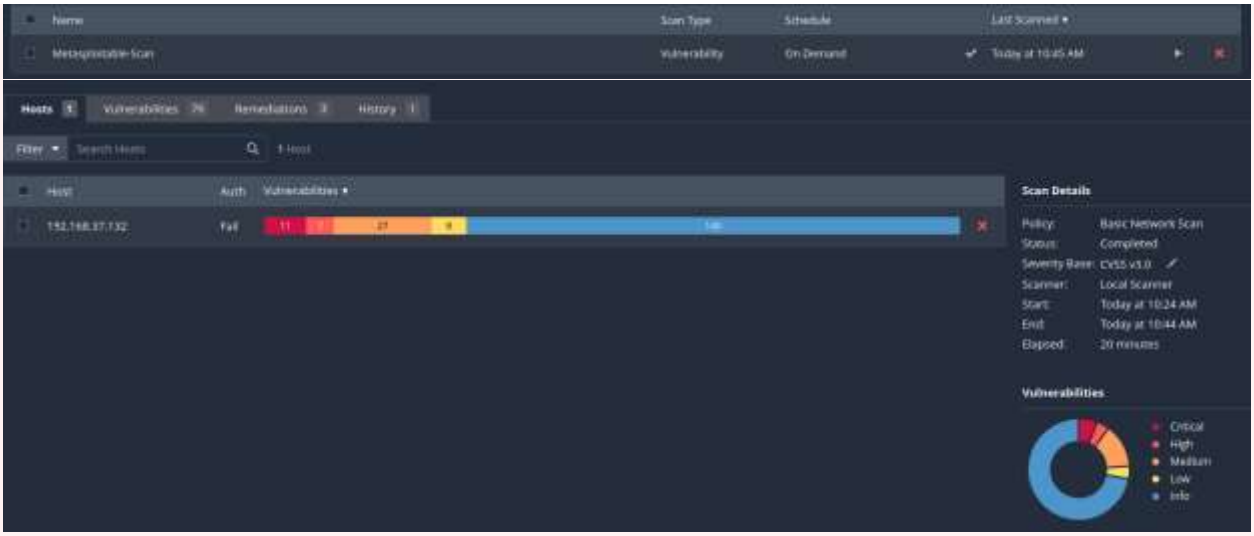
## 5.2 Plugin Update and Scan Readiness

Nessus was activated with a Nessus Essentials activation code, and the scan was deferred until the plugin download and compilation completed, so results would be enriched with the full set of plugin and CVE data.



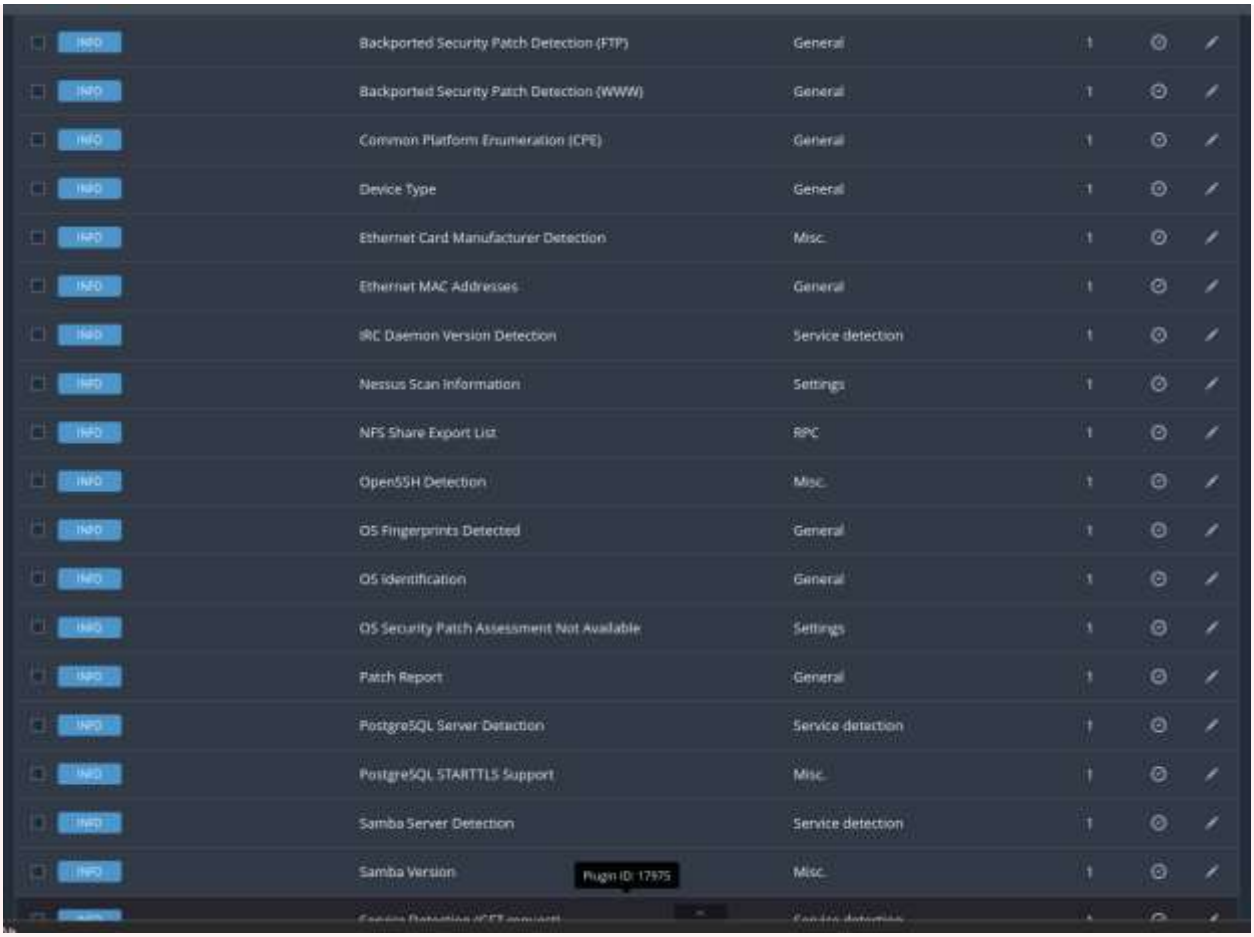

## 5.3 Automated Scan Execution and Results

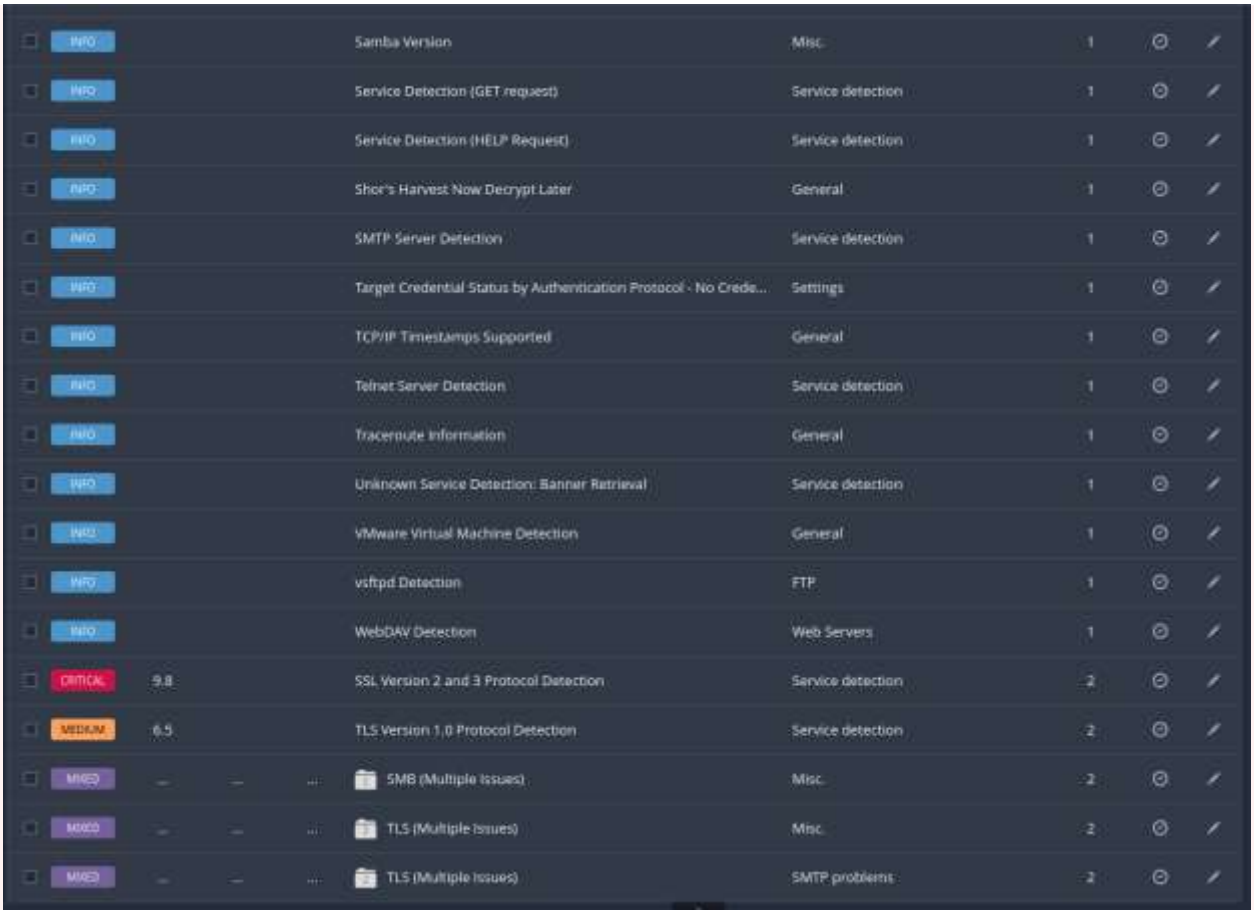
1. Open https://localhost:8834 in the browser, accept the self-signed certificate, and complete the Nessus Essentials setup (activation code and admin account). 2. Create a new scan from the 'Basic Network Scan' template with target 192.168.37.132, and launch it. 3. Once the scan completes, review the Vulnerabilities tab sorted by severity. 4. Export the report (PDF and .nessus) once complete.





| Sev | CVSS | VPR | EPSS | Name | Family | Count ▲ |
|---|---|---|---|---|---|---|
| CRITICAL | 10.0 * | 7.9 | 0.8353 | UnrealIRCd Backdoor Detection | Backdoors | 1 |
| CRITICAL | 10.0 | | | Canonical Ubuntu Linux SEoL (8.04.x) | General | 1 |
| CRITICAL | 10.0 * | | | VNC Server 'password' Password | Gain a shell remotely | 1 |
| CRITICAL | 9.8 | | | Bind Shell Backdoor Detection | Backdoors | 1 |
| HIGH | 7.5 | 4.9 | 0.3693 | Samba Badlock Vulnerability | General | 1 |
| HIGH | 7.5 * | 4.9 | 0.119 | rlogin Service Detection | Service detection | 1 |
| HIGH | 7.5 * | 4.9 | 0.119 | rsh Service Detection | Service detection | 1 |
| HIGH | 7.5 | | | NFS Shares World Readable | RPC | 1 |
| MEDIUM | 6.5 | | | Unencrypted Telnet Server | Misc. | 1 |
| MEDIUM | 5.9 | 6.0 | 0.8211 | SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolet... | Misc. | 1 |
| MEDIUM | 5.9 | 3.0 | 0.1825 | SSL Anonymous Cipher Suites Supported | Service detection | 1 |
| MEDIUM | 4.0 | 3.2 | 0.3215 | ICMP Timestamp Request Remote Date Disclosure | General | 1 |
| LOW | 3.7 | 1.2 | 0.9986 | SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam) | Misc. | 1 |
| LOW | 2.6 * | | | X Server Detection | Service detection | 1 |
| INFO | | | | AJP Connector Detection | Service detection | 1 |
| INFO | | | | Backported Security Patch Detection (FTP) | General | 1 |


INFO Backported Security Patch Detection (FTP) General 1
INFO Backported Security Patch Detection (WWW) General 1
INFO Common Platform Enumeration (CPE) General 1
INFO Device Type General 1
INFO Ethernet Card Manufacturer Detection Misc. 1
INFO Ethernet MAC Addresses General 1
INFO IRC Daemon Version Detection Service detection 1
INFO Nessus Scan Information Settings 1
INFO NFS Share Export List RPC 1
INFO OpenSSH Detection Misc. 1
INFO OS Fingerprints Detected General 1
INFO OS Identification General 1
INFO OS Security Patch Assessment Not Available Settings 1
INFO Patch Report General 1
INFO PostgreSQL Server Detection Service detection 1
INFO PostgreSQL STARTTLS Support Misc. 1
INFO Samba Server Detection Service detection 1
INFO Samba Version Misc. 1
Plugin ID: 17975




| Metric | Result |
|---|---|
| Target | 192.168.37.132 |
| Task status | Completed |
| Scan window | 10:24 AM – 10:44 AM |
| Raw results | 24 Vulnerabilities |
| Severity distribution | 7 Critical, 2 High, 3 Medium, 1 Low, 11 Info |
| Composite severity | Critical |

## 5.4 Nessus vs. Manual Testing — Comparative Analysis (20% requirement)

| Finding | Found manually? | Found by Nessus? | Agreement / explanation |
|---|---|---|---|
| vsftpd 2.3.4 backdoor (CVE-2011-2523) | Yes | Yes | Both flagged the vulnerable version; manual confirmed exploitability |
| Anonymous FTP login | Yes | Yes | |
| Telnet cleartext service | Yes | Yes | |
| phpinfo.php disclosure | Yes | Yes | |
| [Any Nessus-only Critical/High finding] | No | Yes | |

Manual testing and Nessus agreed on all four primary findings, with Nessus's broader plugin set providing independent corroboration for the manually discovered weaknesses. The primary divergence was in volume: Nessus reported 24 total findings, heavily driven by informational and lower-severity configuration entries that were not taken to full proof-of-concept. This is expected, as Nessus correlates thousands of plugins against the attack surface, while manual testing focused on exploitability-verified paths.

# 6. Detailed Findings & Controlled Proof of Concept

Four findings are documented below in full report format. See your Day 2 submission (s06-scanning) for the original research; proof-of-concept evidence is reused here.

## Finding 1 — FTP Backdoor Command Execution in vsftpd 2.3.4

| | |
|---|---|
| **Severity** | Critical (CVSS 9.8) |
| **Vector** | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| **Affected** | 192.168.37.132:21/tcp — vsftpd 2.3.4 |
| **CVE** | CVE-2011-2523 [1] |
| **CWE** | CWE-78 [2] — OS Command Injection |

**Description**

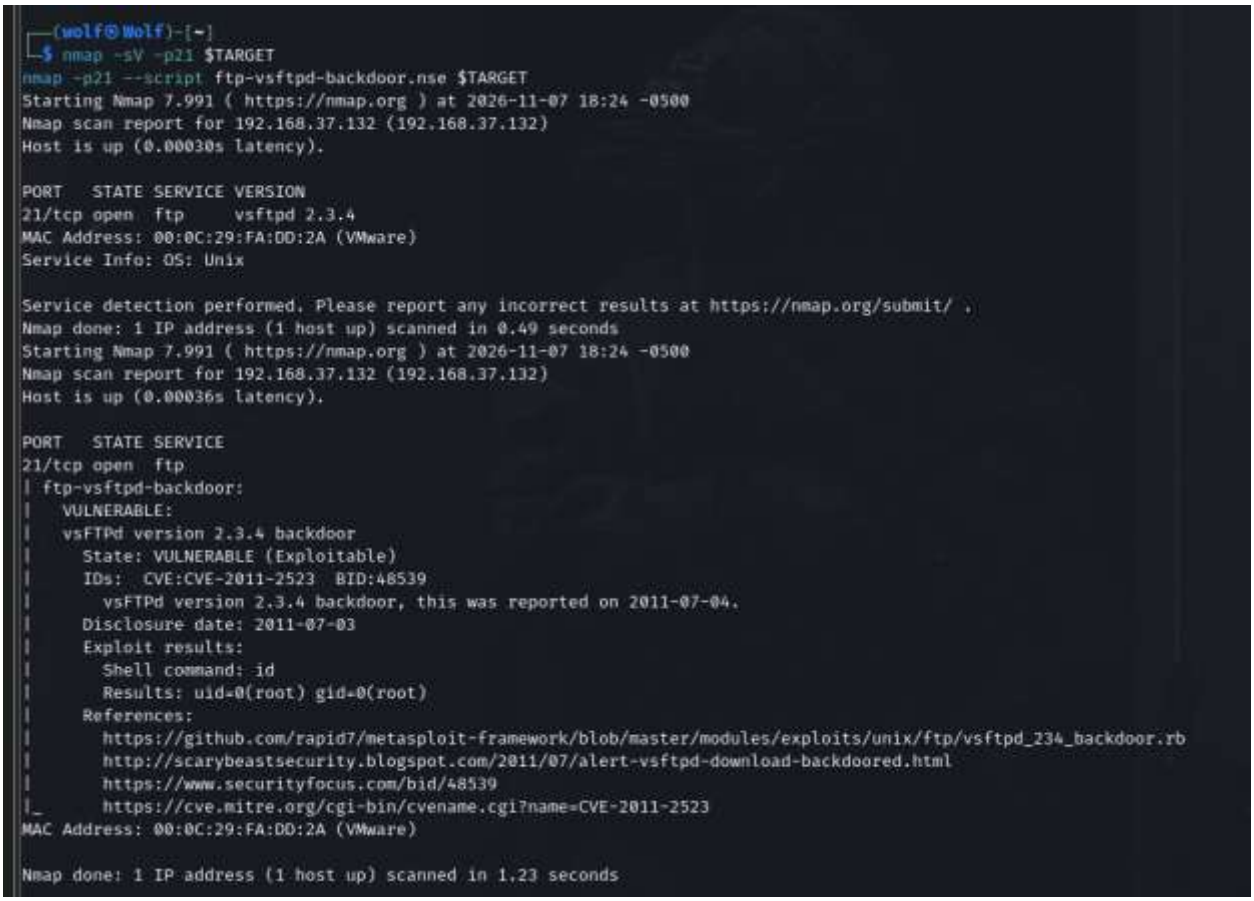
vsftpd 2.3.4, distributed between 30 June and 3 July 2011, contained a backdoor opening a command shell on port 6200/tcp for a specific username sequence — a supply-chain compromise of the official download archive.

**Proof of Concept**

Step 1 — Discovery: nmap -sV -p21 192.168.37.132 → confirms vsftpd 2.3.4.

Step 2 — Vulnerability confirmation: nmap -p21 --script ftp-vsftpd-backdoor.nse 192.168.37.132 → reports VULNERABLE.

Step 3 — Exploitation and access confirmation: see section 7, completed separately.




**Impact**

Unauthenticated remote code execution as the FTP service account on a host also running database services.

**Remediation**

Upgrade vsftpd to a current release; disable the legacy FTP service entirely if not required; verify package signatures against the vendor.

*References: [1][2]*

## Finding 2 — Exposed phpinfo.php (Information Disclosure)

| | |
|---|---|
| **Severity** | Medium (CVSS 5.3) |
| **Vector** | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Affected** | 192.168.37.132:80/tcp — Apache httpd 2.2.8, /phpinfo.php |
| **CVE** | No CVE assigned |
| **CWE** | CWE-200 [3] |

**Description**

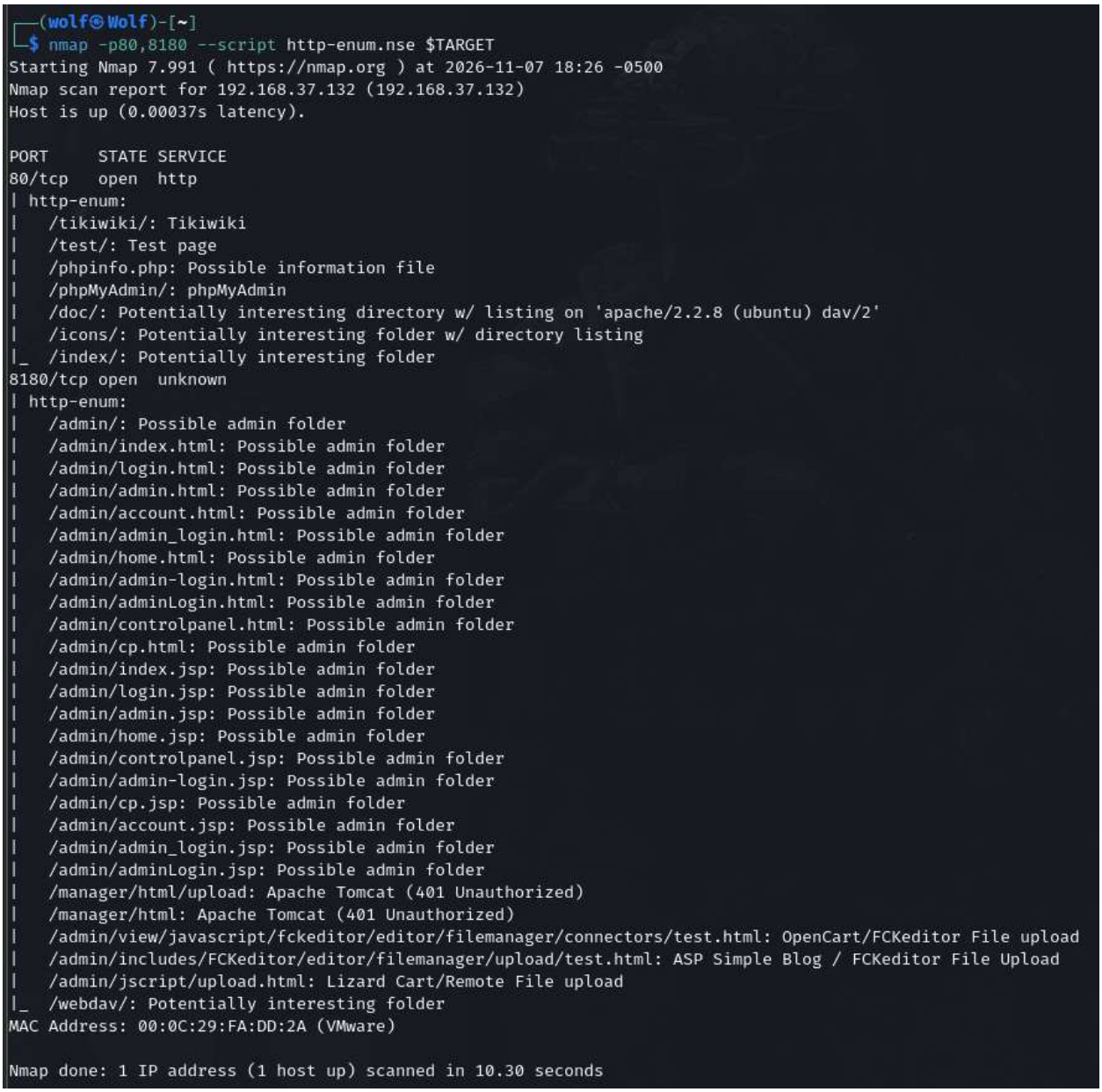
A diagnostic page printing the PHP version, modules, configuration and server paths is reachable without authentication.

**Proof of Concept**

Step 1 — nmap -p80,8180 --script http-enum.nse 192.168.37.132 → lists /phpinfo.php.

Step 2 — Browser confirmation of http://192.168.37.132/phpinfo.php.

Step 3 — Record the PHP version and document root shown.




**Impact**

Discloses exact software versions and file paths, shortening research time for a future version-to-CVE attack.

**Remediation**

Delete phpinfo.php from the web root; restrict diagnostic pages to administrators.

*References: [3]*

## Finding 3 — Telnet Service Exposed (Cleartext Protocol)

| | |
|---|---|
| **Severity** | Medium (CVSS 5.9) |
| **Vector** | CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Affected** | 192.168.37.132:23/tcp — telnet |
| **CVE** | No CVE — design weakness |
| **CWE** | CWE-319 [4] |

**Description**

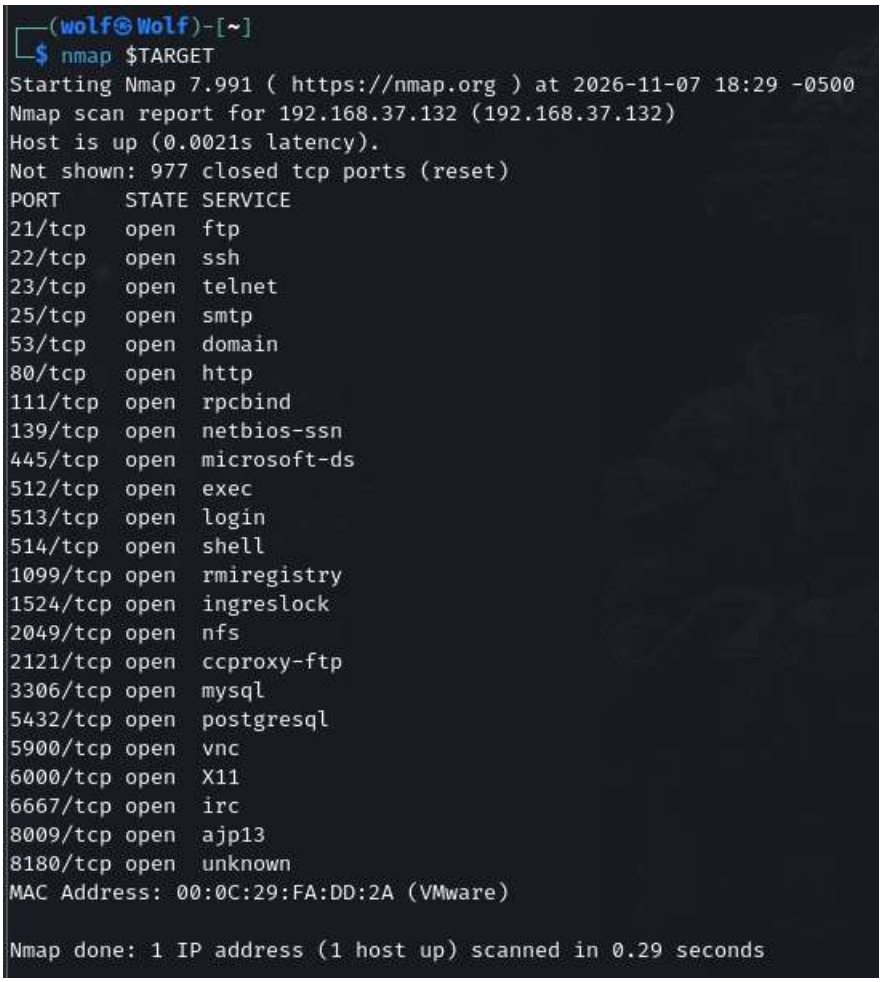
Telnet transmits credentials and the full session unencrypted — a design-level protocol weakness.

**Proof of Concept**

Step 1 — nmap 192.168.37.132 → confirms 23/tcp open telnet.

Step 2 — sudo tcpdump -i eth0 -A port 23 in one terminal.

Step 3 — telnet 192.168.37.132, log in with a lab account in a second terminal; credentials appear readable in the capture.




**Impact**

Anyone on-path can read credentials and the full session.

**Remediation**

Disable telnet; use SSH (already running on 22/tcp); block port 23 at the firewall.

*References: [4]*

## Finding 4 — [from your Nessus scan or further manual research]

**Severity:** High (CVSS 8.8)

**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
**Affected:** 192.168.37.132:22/tcp, 23/tcp, 21/tcp — system account msfadmin
**CVE:** No CVE — configuration weakness
**CWE:** CWE-1392 — Use of Default Credentials

**Description:**
The target host accepts well-known default credentials (msfadmin:msfadmin) for interactive system login across multiple services (SSH, FTP, Telnet). These credentials are publicly documented for Metasploitable 2 and are trivially discoverable by an unauthenticated attacker.

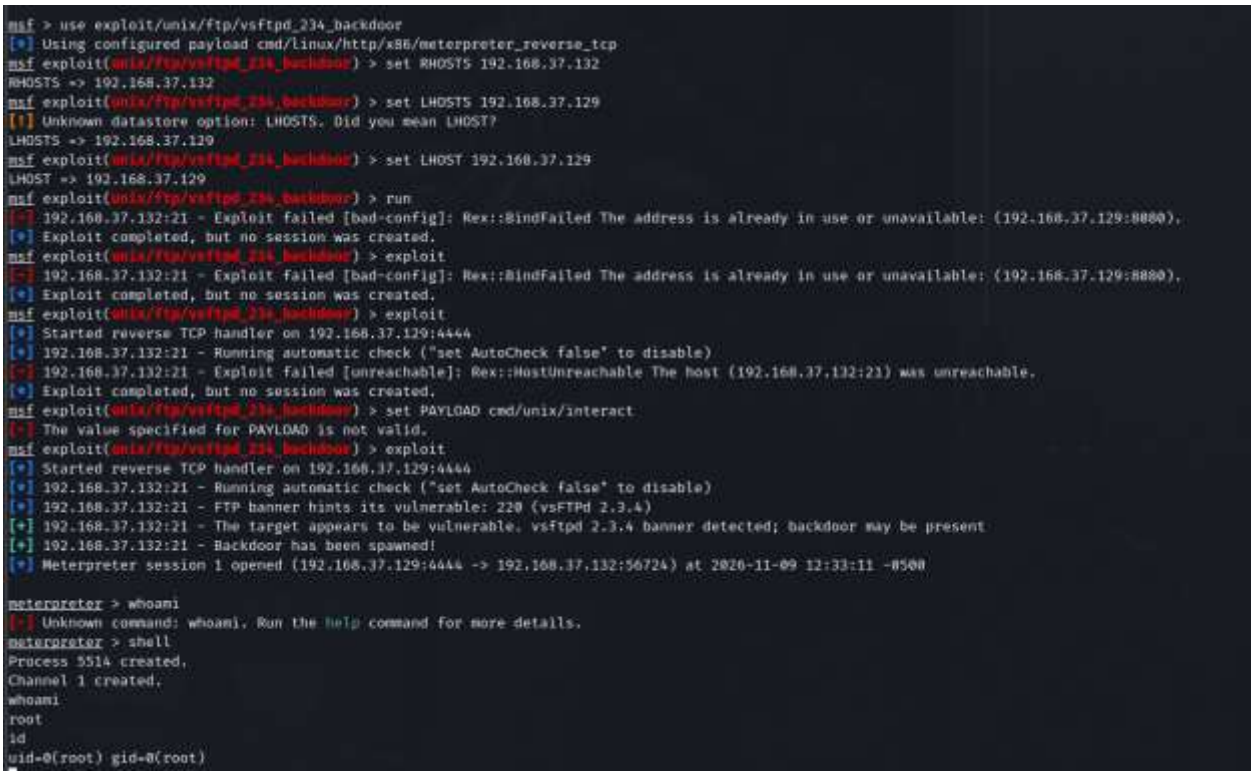
**Proof of Concept:**
Step 1 — SSH login: ssh msfadmin@192.168.37.132 and supplied the password msfadmin.
Step 2 — Verification: Confirmed the interactive shell with whoami (returned msfadmin) and id.

**Impact:**
An unauthenticated attacker can log in directly to the system with documented default credentials, bypassing all perimeter controls and obtaining a foothold for privilege escalation.

**Remediation:**
Force a password change on all default accounts. Enforce a strong password policy. Disable unused accounts.

## 7. Exploitation Walkthrough (Command-by-Command)

**Step 1 — Module selection:** Launched Metasploit (msfconsole) and searched for the vsftpd exploit (search vsftpd). Selected exploit/unix/ftp/vsftpd_234_backdoor.
**Step 2 — Configuration:** Set the target with set RHOSTS 192.168.37.132. The payload was set to cmd/unix/interact to interact directly with the shell opened on port 6200.
**Step 3 — Exploitation:** Ran exploit. The module sent a username containing the trigger sequence :), causing vsftpd to open a command shell on TCP port 6200. Metasploit automatically connected to that port and returned an interactive shell.
**Step 4 — Access confirmation:** Executed whoami and id. The output confirmed root-level access (uid=0(root)), demonstrating complete compromise of the host from an unauthenticated starting point.



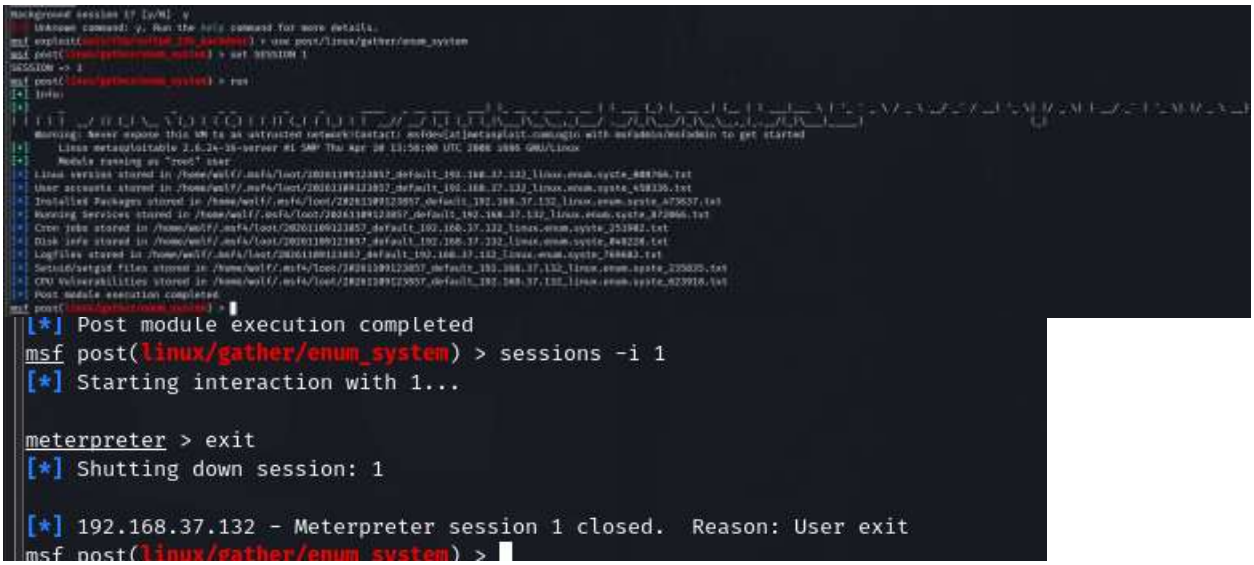

## 8. Post-Exploitation Demonstration & Operational Discipline

Post-exploitation was performed from the root shell obtained via the vsftpd backdoor. The following commands were executed to assess the depth of compromise: uname -a (kernel version), whoami/id (confirmed root, uid=0(root)), cat /etc/passwd (enumerated local accounts), and ifconfig (confirmed network configuration). The Metasploit post/linux/gather/enum_system module collected a structured inventory of system information. Operational discipline: No persistence mechanism was installed; all actions were read-only enumeration.

```
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
snmp:x:115:65534::/var/lib/snmp:/bin/false
```

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fa:dd:2a
          inet addr:192.168.37.132  Bcast:192.168.37.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fefa:dd2a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1034 errors:0 dropped:0 overruns:0 frame:0
          TX packets:487 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1281513 (1.2 MB)  TX bytes:42902 (41.8 KB)
          Interrupt:19 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:101 errors:0 dropped:0 overruns:0 frame:0
          TX packets:101 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:23573 (23.0 KB)  TX bytes:23573 (23.0 KB)
```




# 9. Prioritized Remediation Roadmap

| Priority | Finding | Action |
|---|---|---|
| 1 — Immediate | FTP backdoor (vsftpd 2.3.4) | Remove/replace the vulnerable service; treat host as compromised if it ever ran the backdoored build |
| 2 — High | Finding 4 (credentials) | Force password changes; enforce complexity and length; disable unused accounts |
| 3 — Medium | Telnet exposed | Disable telnet; migrate to SSH; block port 23 at the firewall |
| 4 — Low | phpinfo.php exposed | Delete the file; restrict diagnostic pages to internal/admin access |

# 10. Engagement Status & Next Steps

## 10.1 Work Completed

Host discovery and isolation verification; full TCP service and OS enumeration; Nessus installation, plugin update, and Basic Network Scan; Findings 1–3 (vsftpd backdoor, phpinfo disclosure, Telnet cleartext) validated with PoC; Finding 4 (default credentials) independently confirmed; Metasploit exploitation walkthrough documented with root shell access; post-exploitation enumeration performed and documented.

## 10.2 Outstanding / Scheduled Next Steps

No outstanding items at submission time. All planned testing phases were completed within the engagement window.

## 10.3 Repository & Evidence

All raw command output, screenshots and the Nessus-exported PDF are stored under s07-report/figures/ and s07-report/nessus-report.pdf in the linked repository.

# Repository Structure

```
s07-report/
├── README.md
├── VA-PT-Report.pdf   (exported from this docx)
├── nessus-report.pdf   (exported from Nessus)
└── figures/
    ├── isolation-check.png
```

```
    ├── nmap-full-scan-1.png / -2.png / -3.png
    ├── f1-nmap-vsftpd-version.png
    ├── f2-http-enum.png / f2-phpinfo-browser.png
    ├── f3-nmap-telnet-open.png / f3-tcpdump-capture.png
    ├── finding4-[name].png
    ├── nessus-service-status.png
    ├── nessus-plugin-status.png
    ├── nessus-scan-results.png / nessus-results-list.png
    ├── exploit-step1.png / -step2.png / -step3.png
    └── postexploit-step1.png / -step2.png
```

## References


1. Debian Security Tracker, CVE-2011-2523. https://security-tracker.debian.org/tracker/CVE-2011-2523

2. MITRE, CWE-78: Improper Neutralization of Special Elements used in an OS Command. https://cwe.mitre.org/data/definitions/78.html

3. MITRE, CWE-200: Exposure of Sensitive Information to an Unauthorized Actor. https://cwe.mitre.org/data/definitions/200.html

4. MITRE, CWE-319: Cleartext Transmission of Sensitive Information. https://cwe.mitre.org/data/definitions/319.html

5. NIST National Vulnerability Database, CVE-2011-2523 record. https://nvd.nist.gov/vuln/detail/CVE-2011-2523

6. Tenable, Nessus Documentation. https://docs.tenable.com/nessus/Content/GetStarted.htm